

UAM SAML Web Browser SSO Developer Guide - 6.0.1-GA (AI)

Table of Contents

1. Preface - UAM SAML Web Browser SSO Developer Guide.....	3
2. Introduction to UAM SAML Web Browser SSO Development.....	4
3. UAM SAML Web Browser SSO Configuration.....	7
4. UAM SAML Web Browser SSO Using API.....	16
5. Appendices.....	19

1. Preface - UAM SAML Web Browser SSO Developer Guide

The AccessMatrix Universal Access Management (UAM) server is able to act as the Security Assertion Markup Language (SAML) Service Provider (SP) to achieve SP-initiated web browser Single Sign-Ons (SSO). This document provides information on how to do so.

Intended Reader

This guide is intended as a reference for experienced application developers and security administrators.

Document Scope

This document explains the use of AccessMatrix UAM server as the SP for SP-initiated web browser SSO POST Bindings. The architecture diagram and sequence diagram in this documentation are used to illustrate the simulated SP environment.

For feedback or questions regarding this document, contact doc@i-sprint.com.

Related Documents

For more information, see the following documents in the AccessMatrix Product Suite:

- [UAM Administration Guide](#)
- [AccessMatrix REST API Specification](#)

2. Introduction to UAM SAML Web Browser SSO Development

Security Assertion Markup Language (SAML) is an XML-based open standard for exchanging authentication and authorization data between parties, in particular, between an Identity Provider (IdP) and a Service Provider (SP). The web browser Single Sign-On is one most important requirement that SAML addresses.

SAML Components

Identity Provider

Identity Provider (IdP) is an entity that gives assurances of the identity of the user to the other party. The identity provider is responsible for:

1. Managing users and their identities
2. Issuing credentials
3. Handling user administration
4. Authenticating the user
5. Vouching for the user's identity with the service provider

Service Provider

Service Provider (SP) is an entity that provides Web Services and relies on a trusted IdP for authentication and authorization. The service provider is responsible for:

1. Controlling access to services
2. Validating the asserted identity information from the identity provider (typically by way of verifying a digital signature)
3. Providing access based on asserted identity
4. Managing only locally relevant user attributes, not an entire user profile

SAML Assertions, Protocols, Bindings and Profiles

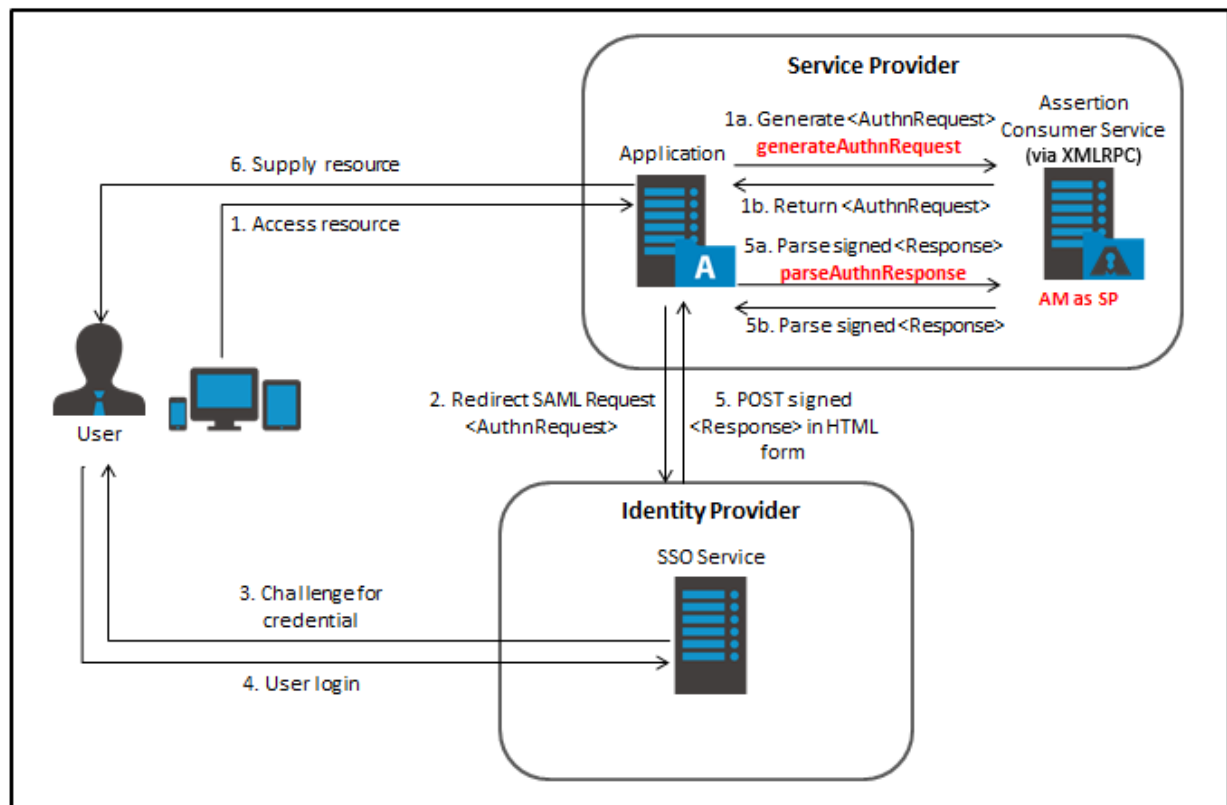
SAML Version 2.0	
SAML Components	Description

SAML Version 2.0	
Assertions	Assertions contain authentication, attribute and entitlement information.
Protocols	Protocols contain the type of requests and responses for obtaining assertions and doing identity management.
Bindings	Bindings refer to communication protocols used in exchanging of requests and assertions.
Profiles	Profile is a combination of bindings, protocols and assertions that together define how the federated identity data is exchanged.
Authentication Context	Authentication Context provides the details of how a user has authenticated with IdP.
Metadata	Metadata refers to the data that is exchanged between Service Provider and Identity Provider while establishing the trust relationship.

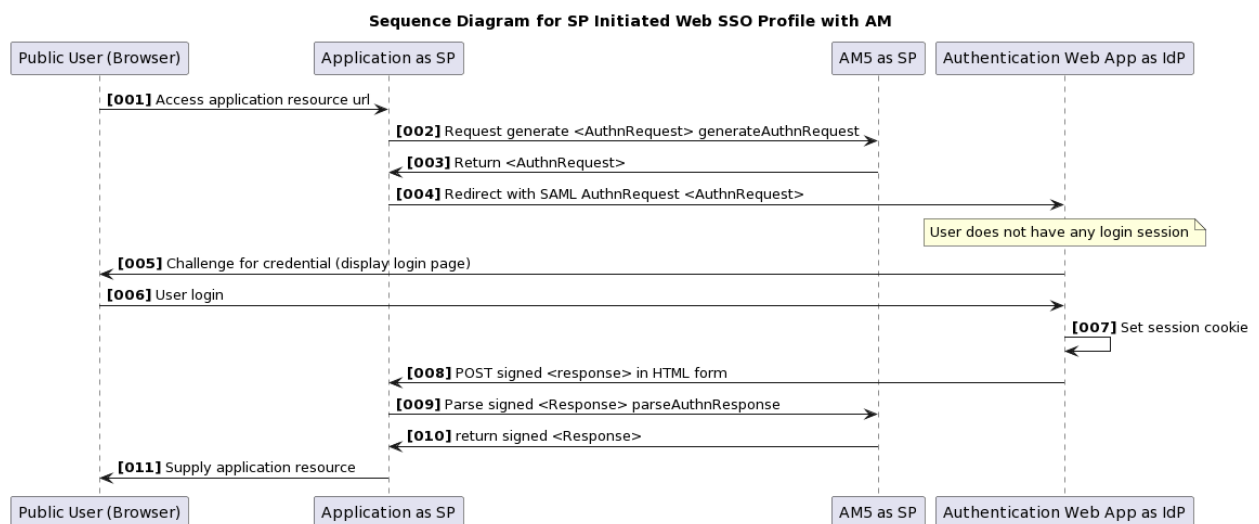
SP-initiated Web Browser SSO

This section contains the process flow of SP-initiated web browser SSO.

SP-initiated SSO with AM5 as SP Process Flow



SP-initiated SSO with AM5 as SP Sequence Diagram



3. UAM SAML Web Browser SSO Configuration

Configure AccessMatrix Server as Service Provider (SP)

This section describes the steps when configuring AccessMatrix server as the Service Provider (SP).

Identity Provider (IdP) Configuration

1. Navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > Identity Provider** and click **Create**.
2. Select "UAM as Service Provider" from the **Implementation** drop-down list and click **Next**. The **Create Identity Provider** page is displayed.
3. Configure the following attributes and save the changes:

Attribute	Description
*Identity Provider Id	Unique Id of Identity Provider.
*Identity Provider Name	Name of Identity Provider.
Description	Description of Identity Provider.
*Id used as issuer	A kind of Id, normally in the URL form to represent the entity IdP.
General Tab	
Digital Signature	
Keystore	The path to the signing keystore file. The key pair(s) in the keystore is/are used for signing the SAML Response generated by the Identity Provider.
Keystore Passphrase	The password of the keystore.
Active Key Alias	The active key for signing.
IdP public key string	It is used to verify response signature (sent by Identity Provider). Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Web Browser SSO Tab	
Service URLs	

Attribute	Description
Single Sign-On Service URLs	The Identity Provider service URL to receive the Authentication request or Single Sign-On request from the Service Provider. This value is used to specify the destination of the SAML Request. URL format: <HTTP Binding> - <SSO URL> - The URL with no binding is taken as a wildcard during API call, i.e. it can be taken as both HTTP-POST/Redirect. This URL with no binding will be exported as HTTP-POST binding during metadata export. - For the new entry URL that is both POST & Redirect, add two entries of different bindings using the same URL. Example: <POST> - <URL1> <Redirect> - <URL1>
Authentication Request	
Authentication Request Required Signing	Enable this setting if SAML request requires signing. Default: false Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Note: For the full list of attributes, refer to UAM Administration Guide - UAM Federated SSO via SAML - Identity Provider (UAM as Service Provider) .	

Service Provider (SP) Configuration

1. Navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > Service Provider** and click **Create**.
2. Select "UAM as Service Provider" from the **Implementation** drop-down list and click **Next**. The **Create Service Provider** page is displayed.
3. Configure the following attributes and save the changes:
 - If SAML request from SP requires signing, configure a keystore with a private key in **Digital Signature** for request signing.
 - When the generated SAML authentication response is encrypted, you need to configure **SP public key string** or configure **Keystore** under **XML Encryption** for SAML decryption.

Attribute	Description
*Service Provider Id	Unique Id of Service Provider.
*Service Provider Name	Name of Service Provider.
Description	Description of Service Provider.
*Id used as issuer	A kind of Id, normally in the URL form to represent the entity SP.
General Tab	
Assertion	
*Assertion Consumer Service URLs	SP's URL to consume SAML assertion. This configuration is needed to specify the ACS URL for the authentication request of the SP-initiated Web browser SSO flow.
Assertion Acceptance time (in seconds)	This is used to indicate the tolerance time of the response's assertion. It validates the response's assertion time, wherein the difference between the assertion's issued time and response's assertion received time must be within the specified tolerance time. It is used by the SP to validate the SAML response assertion. Default: 240 Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Digital Signature	
Keystore	The path to the signature keystore file. The key pair(s) in the keystore is/are for signature verification of the SAML Request received from the Service Provider.
Keystore passphrase	The password of the keystore.
Key alias	The active key for signature verification.
Signature Algorithm	Signing algorithm used for SAML Request. Options: "RSA_SHA1" "RSA_SHA256" Default: RSA_SHA1
XML Encryption	
Keystore	Path to the encryption keystore file. The key pair(s) in the keystore is/are for encrypting the assertion of the SAML Response generated by the Identity

Attribute	Description
	Provider. Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Keystore passphrase	The password of the keystore. Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Key alias	The active key for encryption. Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Others	
SP public key string	It is used as "Request's signature verification key", i.e. to verify request signature (sent by Service Provider) or used as "Response encryption key", i.e. to encrypt SAML response upon generating the corresponding response. Note: If Digital Signature - Keystore or XML Encryption - Keystore is specified, the public key in that keystore will be used instead.
 Note: For the full list of attributes, refer to UAM Administration Guide - UAM Federated SSO via SAML - Service Provider (UAM as Service Provider) .	

Configure AccessMatrix as Identity Provider (IdP)

Identity Provider (IdP) Configuration

1. Navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > Identity Provider** and click **Create**.
2. Select "UAM as Identity Provider" from the **Implementation** drop-down list and click **Next**. the **Create Identity Provider** page is displayed.
3. Configure the following attributes and save the changes:

Attribute	Description
*Identity Provider Id	Unique Id of Identity Provider.
*Identity Provider Name	Name of Identity Provider.
Description	Description of Identity Provider.
Id used as issuer	A kind of Id, normally in URL form to represent the entity IdP.

Attribute	Description
General Tab	
Authentication Response	
Assertion validity time (in seconds)	The validity of SAML Response and SAML Response's Assertion is based on a time-based condition which specifies the validity time range. When AccessMatrix is IdP, and upon generating SAML Response, this attribute value would be used to derive notOnOrAfter time condition of the Assertion Subject and the Response Subject. Time is always in UTC timezone. The time unit of this attribute is in second. Default: 60 Note: Referred by Identity Provider when AccessMatrix serves as Identity Provider.
Web Browser SSO Tab	
Authentication Request	
Acceptance time (in seconds)	This setting is to control the validity of an authentication request, the difference between the time the authentication request is issued and the time the authentication request is received must be within this configured time. Default: 360 Note: Referred by Identity Provider when AccessMatrix serves as Identity Provider.
Digital Signature Tab	
Keystore	The path to the signing keystore file. The key pair(s) in the keystore is/are used for signing the SAML Response generated by the Identity Provider.
Keystore Passphrase	The password of the keystore.
Active Key Alias	The active key for signing.
Signature Algorithm	To change signing algorithm for SAML signature. Default: RSA_SHA256.
i Note: For the full list of attributes, refer to UAM Administration Guide - UAM Federated SSO via SAML - Identity Provider (UAM as Identity Provider) .	

Service Provider (SP) Configuration

1. Navigate to **Administration Dashboard > Configuration > Unified SSO > Federated SSO > SAML > Service Provider** and click **Create**.

-
2. Select "UAM as Identity Provider" from the **Implementation** drop-down list and click **Next**. The **Create Service Provider** page is displayed.
 3. Configure the following attributes and save the changes:
 - If Service Provider signs the SAML request, configure a keystore with a public key in **Digital Signature** for request signature verification.
 - When IdP generates SAML response and if this SAML response/assertion required encryption, you need to enable **Assertion Encryption**. Subsequently, you must configure the public key in **Keystore** under **XML Encryption**.
 - Change **Encryption Algorithm** under **XML Encryption** for SAML response encryption (default: "AES_128").
 - **Response signature scope**, (default: "Response") used by IdP to determine the scope of the SAML response to be signed during SAML response generation.
 - **Attributes to return in the assertion** is used by IdP to determine extra user information to be returned as assertion during SAML response generation.
 - **Allow All Users to Access** is used by IdP to determine the user has access right to access SP's resources during SAML response generation.

Attribute	Description
*Service Provider Id	Unique Id of Service Provider.
*Service Provider Name	Name of Service Provider.
Description	Description of Service Provider.
Id used as issuer	A kind of Id, normally in the URL form to represent the entity SP.
General Tab	
Assertion	
*Assertion Consumer Service URLs	SP's URL to consume SAML assertion. This configuration is needed to determine the recipient of the generated SAML response.
Name Id	
Value	The value to be retrieved from user object as user identity. If user's identity is to be retrieved from User Response (e.g. user's UUID), configure this attribute

Attribute	Description
	to "User Response" instead. Used by IdP to determine the user identity of generated response. Note: Referred by Identity Provider when AccessMatrix serves as Identity Provider.
Attributes	
Attributes to return in the assertion	Upon successful authentication, the specified set of user information to be sent to this SP as part of the assertion. User Response configuration is used to specify these information.
Response	
Response signature scope	It is used when AccessMatrix is IdP, and used to define the scope of the SAML response to be signed, e.g. Response, Assertion and etc. Possible values: "No signature" "Response" "Assertion" Default: Response Note: Referred by Identity Provider when AccessMatrix serves as Identity Provider.
Access Control	
Allow All Users to Access	Enabling this feature allows all authenticated users access this Service Provider. To control user access to the web applications or web services of an SP, this setting must be disabled. To control user access, go to the SAML Application Privilege tab of the User's panel to allocate. Default: true Note: Referred by Identity Provider when AccessMatrix serves as Identity Provider.
Assertion Encryption	It is used when AccessMatrix is IdP, to indicate whether to apply encryption to SAML response's assertion. Default: false Note: Referred by Identity Provider when AccessMatrix serves as Identity Provider.
Digital Signature Tab	
Keystore	Path to the signature keystore file. The key pair(s) in the keystore is/are for signature verification of the SAML request received from the Service Provider.
Keystore Passphrase	The password of the keystore.

Attribute	Description
Active Key Alias	Active key for signature verification.
XML Encryption	
Keystore	Path to the encryption keystore file. The key pair(s) in the keystore is/are for encrypting the assertion of the SAML response generated by the Identity Provider. Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Keystore Passphrase	The password of the keystore. Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Active Key Alias	Active key for encryption. Note: Referred by Service Provider when AccessMatrix serves as Service Provider.
Encryption Algorithm	Used to change the algorithm of SAML Response's assertion encryption. Possible values: "AES_128" "AES_256" Default: AES_128



Note: For the full list of attributes, refer to [UAM Administration Guide - UAM Federated SSO via SAML - Service Provider \(UAM as Identity Provider\)](#).

Configure SAML Sample Program: samlsp-rest

Configure the `/WEB-INF/web.xml` parameters in the sample program: **samlsp-rest-sample.war**.

Parameters	Description
restAPIURL	Configure AccessMatrix Rest API URL
agentKeyStoreURL	Configure agent keystore path to login as agent session.
agentKeyStorePassword	Configure agent keystore password.
agentKeyStoreAlias	Configure agent keystore alias.
idpId	IdP Id configured in AccessMatrix.
spId	SP Id configured in AccessMatrix.

Parameters	Description
splIssuer	SP Id used as issuer in AccessMatrix.
authnContext	This value is constant. It is used by SP to indicate the authenticate context required for the SAML authentication and SAML IdP will take this context to challenge user with authentication method. However, SAML sample program will not demonstrate this for now.
isIDPInitiatedResp	Set to true if it is IdP initiated. Default is false.

4. UAM SAML Web Browser SSO Using API

Authorization Service

The sample program connects to AccessMatrix REST Authorization Service (AuthzSvc) to:

- Generate the authentication request
- Parse the authentication response

Generate Authentication Request

- Use `authz/saml/authnReq/generate` to generate authentication request.
- Refer to the [AccessMatrix REST API Specification](#) for more details.
- Returns:
 - Authentication request, on success.
 - On error, REST Fault or Exception is returned. Refer to [REST Faults or Exceptions](#) for possible error code and message returned.

REST Sample Code

Generate Authentication Request	
URL : <code>authz/saml/authnReq/generate</code>	
Request	
JSON	
<pre>{ "dynamicAgentSession": true, "issuer": "sp.i-sprint.com", "authnContext": "1", "relayState": "/sampleSP.jsp", "binding": "HTTP-Redirect" }</pre>	
Response	
JSON	
<pre>{ "result": { "requestId": "jjlhca...", "samlRequest": "<saml2p:AuthnRequest...>...</saml2p:AuthnRequest>", } }</pre>	

Generate Authentication Request

```
"deflatedSAMLRequest": "fZFRb4IwFIXf...",
"urlEncodedDeflatedSAMLRequest": "fZFRb...",
"idpSSOUrl" : "...",
"authnContexts": ["1"],
"sigAlg": "http://www.w3.org/2001/04/xmldsig-more#rsa-sha256",
"signature": "Dlp...",
"urlEncodedSigAlg": "http%3A...",
"urlEncodedSignature": "bYpe6%2B...",
"urlEncodedRelayState": "http%3A%2F..."
},
"amProcessingTimeMillis": 14885
}
```

Parse Authentication Response

- Use `authz/saml/authnResp/parse` to parse authentication response.
- Refer to the [AccessMatrix REST API Specification](#) for more details.
- Returns:
 - Authentication response, on success.
 - On error, REST Fault or Exception is returned. Refer to [REST Faults or Exceptions](#) for possible error code and message returned.

REST Sample Code

Parse Authentication Response

URL : `authz/saml/authnResp/parse`

Request

JSON

```
{
  "dynamicAgentSession": true,
  "authnResponse": "PD94bWwgdmVyc2lvbj0....",
  "spId": "ServiceProvider",
  "idpId": "DefaultIdentityProvider",
  "idpInitiated": true
}
```

Response

JSON

Parse Authentication Response

```
{
  "result": {
    "assertionId": "ggpdnifblbafecbajjnobjfadlnpmgkphcdlkgpo",
    "authnContext":
"urn:oasis:names:tc:SAML:2.0:ac:classes:PasswordProtectedTransport",
    "requestId": "mdmfhobmboklndfeijngoidmaloiyhjipgambbnj",
    "assertionTime": -722753160,
    "attributes": {},
    "userIdentity": "demouser",
    "authnTime": -722753160,
    "issuer": "i-sprint.com",
    "responseId": "jclbelllilhejoeffahecgfdljnhlnhopdmdiil",
    "authnSesExpiredOn": 0
  }
  "amProcessingTimeMillis": 2081
}
```

5. Appendices

A. REST Faults or Exceptions

Below is the list of SAML Web Browser SSO-related error codes and messages.

Error Code	Error Messages
Invalid Response Exception	
16002	Response does not contain an assertion.
	Issuer is required as part of the response or assertion.
	IdP, <issuer>, is not registered.
	Assertion issue instant is required.
	Failed to retrieve user identity.
Invalid Time Exception	
16003	Assertion issue time is outside the acceptable range (SP's assertion time window). now=<recent time>, assertion.issueInstant=<assertion issue time>, windowInSecs=<assertion time window in seconds> (issueInstant-halfWindow, issueInstant+halfWindow).
	Assertion has expired. Assertion time condition specified by IdP cannot be fulfilled. now=<recent time>, condition.notBefore= <time not before assertion condition>, condition.notOnOrAfter=<time not on or after assertion condition>, condition.timeToleranceInSecs=<tolerance time in seconds> (notBefore-timeTolerance, notAfter+timeTolerance).
Signature Validation Exception	
16004	Neither response nor assertion is signed.
	Failed to check whether element is signed.
Configuration Exception	
16006	Issuer (issuer) must be specified.
	ACS URL (sso-acs-url) must be specified.
